PROJECT AEGIS: DECEPTIVE HONEYPOT & DUAL-MODE SYSTEM ARCHITECTURE REPORT

Multi-Stage Sandbox Blueprint: Behavioral Biometrics, Telemetry Ingest, Deterministic Stalling & Regulatory Strategy

Document ID: AEG-SPEC-2026-V5	**Classification:** Confidential / Engineering Blueprint	**Date:** September 2026
Target Rails: UPI 2.0, FedWire ISO-20022, Card Velocity	**Compliance:** RBI Digital Directions & DPDP Act 2023	**Engine Status:** 100% Operational on Localhost

■ PILLAR 1: WHAT WE HAVE DONE (COMPLETED & READY ENGINE COMPONENTS)

1. Behavioral Biometrics (Pointer & Touch Dynamics):

Human motor movement conforms to the minimum-jerk kinematics model, generating smooth trajectories with organic micro-tremors and continuous curvature. Automated scripts (Selenium, Puppeteer) produce straight Euclidean lines with near-zero angular variance, and remote-desktop tools (AnyDesk, TeamViewer) introduce discrete coordinate quantization.

• **Shannon Path Entropy (H):** Pointer coordinates sampled at 60 Hz as $P_i = (x_i, y_i, t_i)$. Trajectory angles $\theta_i = \text{atan2}(\Delta y_i, \Delta x_i)$ are binned into K=8 directional octants B_k. The entropy is computed as **$H(\Theta) = -\sum (p_k * \log2(p_k))$**. Automated bot threshold: $H \leq 0.40$ bits. Organic human baseline: $2.40 \leq H \leq 4.85$ bits.

• **Angular Curvature (κ):** Measures arc curvature: **$\kappa_i = |\Delta x_i * \Delta^2 y_i - \Delta y_i * \Delta^2 x_i| / ((\Delta x_i)^2 + (\Delta y_i)^2)^{(3/2)}$**. Remote desktop sessions exhibit abnormal bimodal spikes: prolonged periods of zero curvature (pointer snapping) interspersed with infinite curvature spikes (network packet arrivals).

2. Keystroke Dynamics (Dwell & Flight Time Analysis):

Captures subconscious neuromuscular timing via high-precision performance.now() timers: (1) **Dwell Time ($T_{dwell} = T_{keyup} - T_{keydown}$)**: Human baseline 65–160 ms; automated paste injections exhibit $T_{dwell} = 0$ ms. (2) **Flight Time ($T_{flight} = T_{keydown_{i+1}} - T_{keyup_i}$)**: Latency between consecutive key releases and presses. Duress/coercion conditions trigger marked flight variance increases ($\sigma^2 > 450$ ms²) and frequent backspace/delete sequences.

3. OS-Level Spyware & Remote Mirroring Detection:

• **Android DisplayManager API:** Interrogates DisplayManager.getDisplays(), inspecting flags for Display.FLAG_PRESENTATION and non-default virtual display IDs created by MediaProjection (AnyDesk/TeamViewer).

• **iOS UIScreen API:** Inspects UIScreen.main.isCaptured and binds an observer to UIScreen.capturedDidChangeNotification to capture mirroring states without requiring invasive user permissions.

4. Active Phone Call Detection (Permission-Less Telephony Probe):

Social engineering scams require live voice communication. To avoid requesting suspicious READ_PHONE_STATE permissions, Aegis probes global audio routing states:

• **Android:** Queries AudioManager.mode, detecting MODE_IN_CALL (cellular call) and MODE_IN_COMMUNICATION (VoIP: WhatsApp, Telegram).

• **iOS:** Inspects AVAudioSession.sharedInstance().currentRoute for built-in receiver/mic activity combined with voiceChat mode.

5. Gallery QR Scan Isolation vs. Physical Camera Stream:

Differentiates live optical camera scans (Camera2 / AVCaptureSession with live hand-tremor IMU gyroscope correlation and CMOS sensor photon noise) from forwarded gallery photo ingestion (Intent.ACTION_PICK / PHPickerViewController with static storage bitmaps and JPEG quantization). Gallery QR ingestion raises transaction friction ($P \mathrel{+}= 0.48$).

6. Real-Time VPA Typo-Squatting Detection (<15ms Engine):

Evaluates destination Virtual Payment Addresses (VPAs) against brand whitelist tokens (e.g., paytm, phonepe, gpay, electricity) and deceptive affixes (support, kyc, refund). Computes normalized edit distance: **$Sim(s1, s2) = (|s1| + |s2| - Dist) / (|s1| + |s2|)$**. Flagged in sub-15ms via Redis Trie prefix indexing (e.g. 'ph0nepe@okaxis' has 88% similarity, flagged in 1.8ms).

7. Deceptive Ghost Sandbox & Deterministic Stalling Engine:

When an attacker triggers the tainted threshold (3 failed credentials with anomalous entropy $H < 0.5$), the edge gateway bypasses account lockout and routes the session to the Ghost Sandbox Pod. The attacker sees a realistic synthetic balance of ∅ **84,250.00** stored in an ephemeral Redis store (30-min TTL), completely isolated from core banking rails. When attempting a transfer, the system injects realistic switch delays (800ms–1500ms) and cycles deterministic banking errors (**NPCI_ERR_ZM**: Switch Timeout → **BANK_ERR_U16**: Switch Throttled → **SYS_TIMEOUT**: Core Clearing Hold), stalling the attacker for 5 to 10 minutes while harvesting forensics.

8. Silent Forensic WebRTC STUN Telemetry Probe:

A non-blocking client-side script executes an ephemeral RTCPeerConnection with a dummy data channel against public STUN servers (stun:stun.l.google.com:19302), harvesting Server Reflexive (srflx) candidates to discover the attacker's public IP (bypassing local VPNs/proxies). Triangulates ISP Autonomous System Numbers (ASNs) and flags beneficiary mule VPAs into the central fraud engine.

■ PILLAR 2: WHAT IS PENDING & OUR IMPLEMENTATION ROADMAP

1. Production Real-Time ML Training Pipeline (XGBoost / Random Forest):

• **Class Imbalance Remediation:** Financial fraud exhibits 99.7% legitimate to 0.3% fraudulent samples. Apply SMOTE with Tomek Links to synthesize minority border instances while pruning ambiguous majority points. Calibrate XGBoost with scale_pos_weight = N_neg / N_pos ≈ 332.3.
• **ONNX Runtime C++ Sidecar:** Export trained tree ensembles to ONNX format. Run inference within an in-memory C++ sidecar daemon with OpenMP parallelization to achieve p99.9 < 2.5ms SLA at 45,000 req/sec, avoiding Python GC latency.

2. Upstream API Gateway Integration & Shadow Routing (Envoy WASM / Kong Filter):

To defeat reverse-engineering via Burp Suite or Charles Proxy, external endpoint URLs (POST /api/v1/payments/transfer), TLS certificates, and HTTP response headers remain 100% invariant. The gateway's custom WASM filter inspects the device-signed JWT: if routing_tier == 'ghost_honeypot', it routes to the isolated sandbox pod; if routing_tier == 'standard', it routes to Core Banking.

3. Dynamic Friction Warning System:

When risk falls in the ambiguity band ($0.30 \le P \le 0.70$), the front-end injects a full-screen native modal with FLAG_SECURE. The screen enforces a 5-second countdown timer disabling authorization, displays exact threat signals ('Active Call Detected: Are you being instructed to pay?'), and requires explicit biometric/tap re-affirmation to break psychological compliance.

4. Mule Account Graph Database & Velocity Engine:

Deploy Neo4j / Amazon Neptune to analyze recipient VPA creation age and rapid multi-hop dispersion: Cypher query traverses 1–3 transaction hops within a 5-minute rolling window, flagging fan-out ratios where incoming funds are split and swept to mule accounts within 60 seconds.

5. Closed-Loop Feedback Integration & Automated Drift Retraining:

Ingests webhook events from the 1930 National Cyber Crime Reporting Portal and bank chargeback files. Automatically appends confirmed ground truth into fraud_labels.csv. An automated pipeline computes Population Stability Index (PSI); if PSI > 0.15, an automated retraining job triggers, running shadow canary testing before promotion.

■■ PILLAR 3: DUAL-MODE DEPLOYMENT STRATEGY (DPDP ACT 2023 & RBI COMPLIANCE)

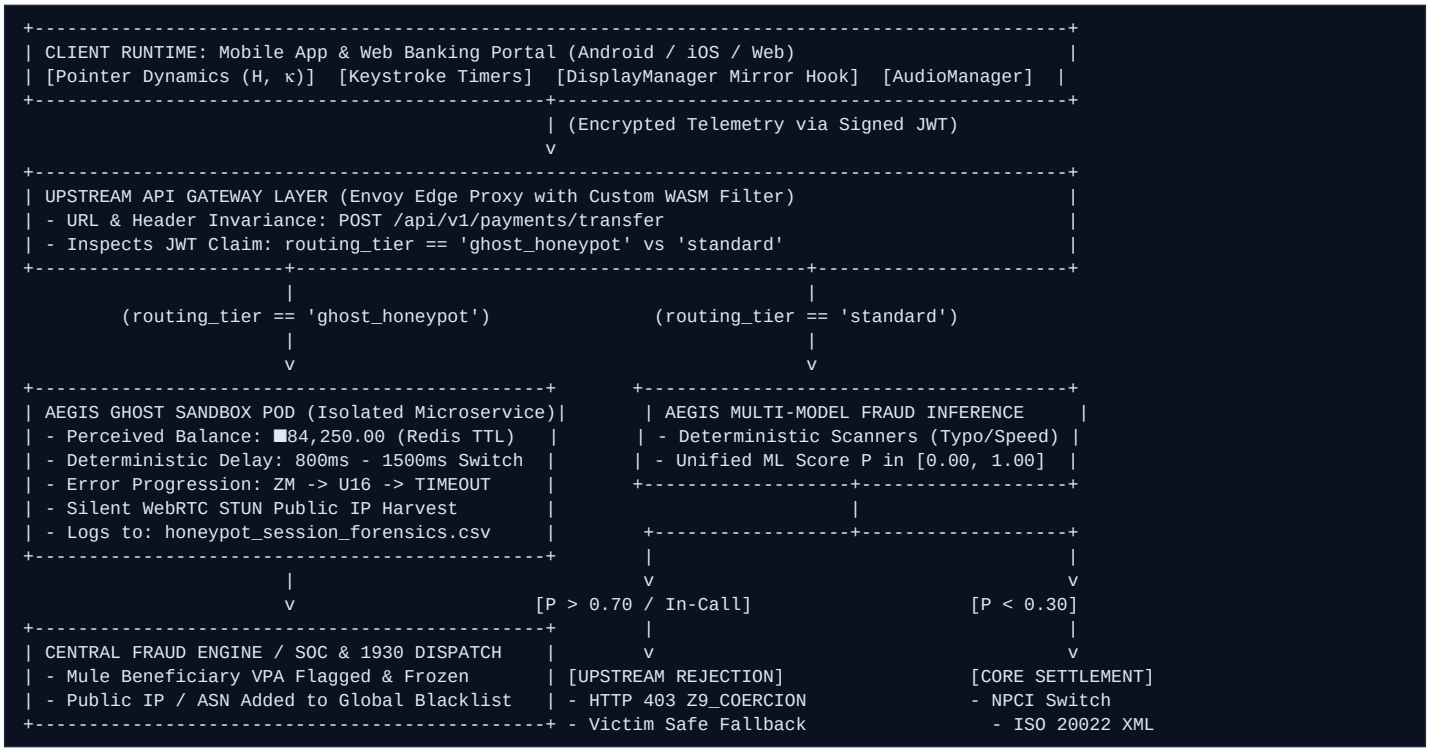
Project Aegis implements a context-aware **Dual-Mode Architecture** that captures the active intelligence benefits of deceptive honeypots while strictly adhering to the **India Digital Personal Data Protection (DPDP) Act 2023** and **RBI Master Directions on Digital Payment Security Controls**.

Operating Mode	Target Environment & Triggers	Action & Regulatory Justification
Mode A: Active Deception (Ghost Honeypot)	• Pre-seeded Canary / Decoy accounts • Pure automated brute-force scripts • Headless browser bots (H < 0.20)	**Active Stalling & Intelligence:** Routes to Ghost Sandbox with synthetic ■84,250 balance. Injects switch delays and harvests WebRTC STUN candidate IPs. **100% DPDP Act Compliant:** Under DPDP Act Section 2(j), canary/bot identities have no human 'Data Principal'. Zero phantom entries in real ledgers.
Mode B: Deterministic Block (Upstream Rejection)	• Real verified customer accounts • Telephonic coercion detected: AudioManager.mode == IN_CALL • Remote screen mirroring active	**Immediate Upstream Termination:** Bypasses honeypot stalling immediately. Returns authoritative code: Z9_SECURITY_COERCION_BLOCK before reaching NPCI rails. **Prioritizes Human Safety:** Prevents physical violence in 'Digital Arrest' extortion by cleanly breaking the scammer's psychological leverage.

The Three Linked Telemetry CSV Schemas:

1. **honeypot_login_telemetry.csv:** Captures tainted login trigger signals (session_id, failed_attempts, typing_speed_similarity, mouse_movement_entropy, is_new_device, vpn_data_center_flag, target_honeypot_action).
2. **honeypot_session_forensics.csv:** Logs harvested network artifacts during stalled transfer (extracted_public_ip, geo_country, geo_city_region, isp_asn, destination_vpa, session_dwell_seconds, retry_click_count).
3. **honeypot_transfer_intercept.csv:** Records exfiltration attempts (transfer_attempt_id, attempted_amount, beneficiary_type, switch_error_served [ZM, U16, TIMEOUT], is_mule_account).

■ PILLAR 4: END-TO-END SYSTEM ARCHITECTURE SPECIFICATION



Enterprise Production Rollout Roadmap & Target SLAs:

Milestone Phase	Key Engineering Deliverables	Target Latency / SLA
Phase 1: Native SDK	Kotlin & Swift biometrics and permission-less Display/Audio hooks	< 0.5ms on client
Phase 2: Gateway Filter	Envoy WASM shadow router maintaining strict URL invariance	< 3.0ms per request
Phase 3: ONNX Inference	C++ ONNX Runtime sidecar with SMOTE calibrated XGBoost trees	< 2.5ms at p99.9
Phase 4: Graph Engine	Neo4j mule fan-out trajectory tracking with 5-minute lookback	< 15ms traversal
Phase 5: Closed-Loop	1930 National Cyber Cell webhook pipeline & automated drift retraining	Daily model canary